

Dev Legacy — Compte-rendu de mission

Maintenance & modernisation — **Unify**

Projet	Unify — plateforme sociale de running (React Native / Expo + microservice NestJS)
Équipe	Tim Hrdy — Chantiers 1 & 2, rapport · Guillaume Lafay — Chantier 3
Dépôt	https://github.com/guiguil03/Unify-App
Branche	mission/dev-legacy (branche dédiée — 5 commits atomiques)
Pull Request	https://github.com/guiguil03/Unify-App/pull/11
Dates d'intervention	5–6 juin et 12 juin 2026

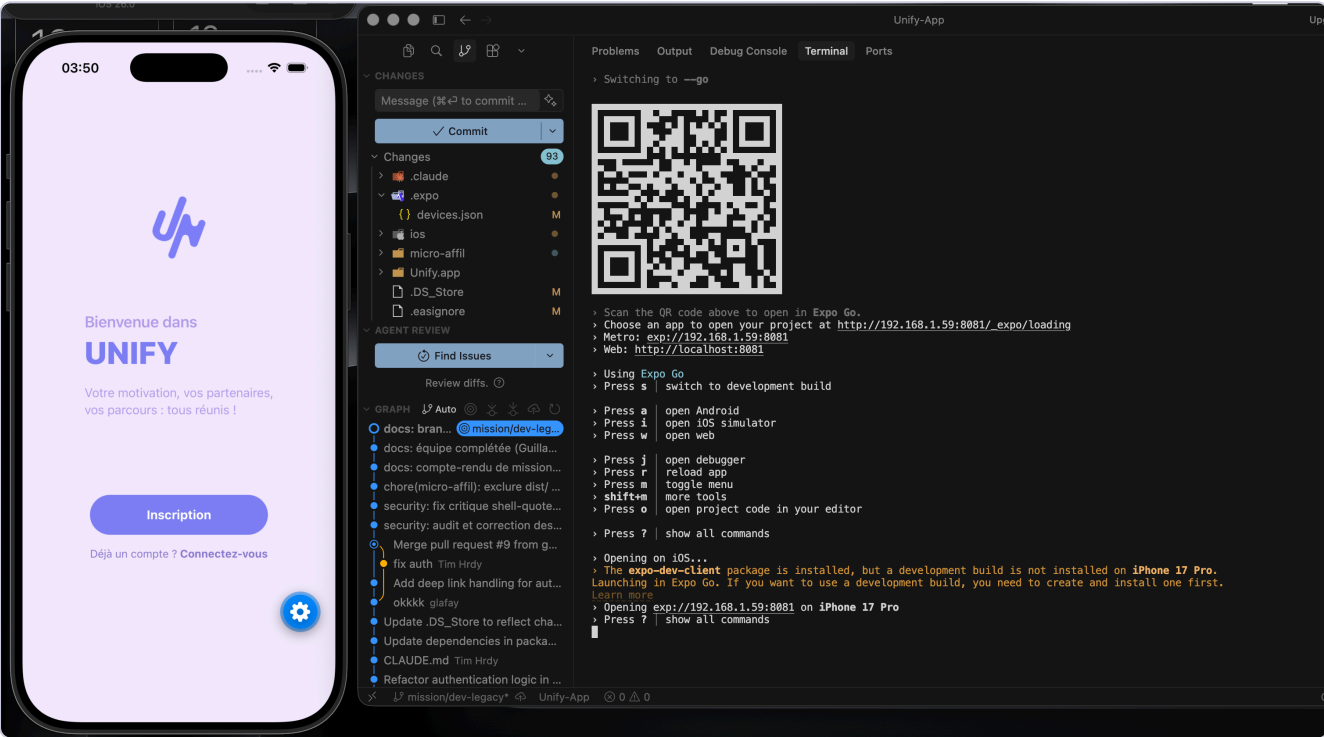
1. Reprise en main

État du projet au retour. Monorepo à deux têtes : l'app mobile Expo SDK 55 / React Native 0.83 à la racine, et un microservice NestJS 10 (`micro-affil/`) en Clean Architecture. Le backend de données est Supabase.

Temps pour le faire tourner : ~15 min pour l'app (`npm install + expo start` , rien de cassé côté lancement) ; le microservice **ne compilait pas** (voir Chantier 2).

Frictions rencontrées à la reprise :

- **Build du microservice cassé :** `npm run build` échoue (`error TS5095`) — c'est devenu notre Chantier 2.
- **Lint du microservice cassé :** 21 erreurs de parsing (ESLint tentait d'analyser les `.d.ts` générés dans `dist/`).
- **Dépendance morte :** `firebase` déclaré dans `package.json` mais **importé nulle part** (l'app utilise exclusivement Supabase) — et c'est lui qui portait la faille **critique** `protobufjs` .
- **Dépendances parasites :** deux librairies React Native (`@react-navigation/bottom-tabs` , `@react-native-community/datetimerpicker`) déclarées... dans le backend NestJS, sans aucune référence dans `src/` .
- **Artefact de build versionné :** un dossier `Unify.app/` (binaire iOS compilé, ~70 fichiers) committé dans le dépôt par erreur.
- `.env` requis pour lancer le microservice (variables Supabase) — non versionné, à recréer.



Le projet qui démarre : écran d'accueil Unify dans le simulateur iOS + serveur Metro/Expo dans le terminal

2. Tableau de bord « avant »

Mesures prises **avant toute intervention** (5 juin 2026) :

Indicateur	App mobile (racine)	Microservice <code>micro-affil</code>
Vulnérabilités (<code>npm audit</code>)	24 (1 critique, 6 élevées, 17 modérées)	36 (1 critique, 17 élevées, 14 modérées, 4 faibles)
Dépendances obsolètes (<code>npm outdated</code>)	40+ paquets en retard (dont React Navigation v6 → v7, ESLint 8 → 10)	NestJS 10 (latest : 11), <code>@typescript-eslint</code> 6 (latest : 8)
Build / lint OK ?	Tests OK · lint non bloquant	Build KO (TS5095) · Lint KO (21 erreurs)
Nb de tests / couverture	14 tests, 4 suites (filet existant)	7 tests, 2 suites · couverture 100 % des unités testées
Temps de réponse clé (back)	—	non mesuré (env Supabase requis)

Sortie `npm audit` initiale (extraits réels) :

```
# App mobile (racine)
24 vulnerabilities (17 moderate, 6 high, 1 critical)

protobufjs <=7.5.7 [CRITIQUE]
  * Arbitrary code execution in protobufjs
  * Prototype injection in generated message constructors
  via: firebase → @firebase/firestore → @grpc/proto-loader → protobufjs

lodash <=4.17.23 [ÉLEVÉE]
  * Code Injection via `_.template`
  * Prototype Pollution via `_.unset` / `_.omit`

# Microservice micro-affil
36 vulnerabilities (4 low, 14 moderate, 17 high, 1 critical)
  multer / express / body-parser / qs [ÉLEVÉES] – pile HTTP NestJS 10
```

Note (12/06) — Les captures ci-dessous, prises le 12/06 sur l'état pré-mission reconstitué (branche `features/post-profil`), affichent **26** vulnérabilités au lieu des 24 mesurées le 05/06 : **deux advisories ont été publiés entre nos deux sessions** (`shell-quote` , critique, et `@grpc/grpc-js` , élevée). Les deux sont déjà corrigés sur la branche de mission — commit dédié pour `shell-quote` , et `@grpc/grpc-js` éliminé avec la suppression de `firebase` . Illustration directe du constat du §8 : la sécurité des dépendances est un flux, pas un état.

```
npm audit — état pré-mission (12/06)

timhrdy@MacBook-Pro-de-Tim Unify-App % npm audit
# npm audit report

[...]
```

protobufjs <=7.5.7
Severity: critical
Arbitrary code execution in protobufjs - <https://github.com/advisories/GHSA-xq3m-2v4x-88gg>
protobuf.js: Code injection through bytes field defaults in generated toObject code - <https://github.com/advisories/GHSA-66ff-xgx4-vchm>
protobuf.js: Denial of service from crafted field names in generated code - <https://github.com/advisories/GHSA-2pr8-phx7-x9h3>
protobuf.js: Prototype injection in generated message constructors - <https://github.com/advisories/GHSA-fx83-v9x8-x52w>
protobuf.js: Code generation gadget after prototype pollution - <https://github.com/advisories/GHSA-75px-5xx7-5xc7>
protobuf.js: Process-wide denial of service through unsafe option paths - <https://github.com/advisories/GHSA-jvwf-75h9-cwgg>
protobuf.js: Denial of service through unbounded protobuf recursion - <https://github.com/advisories/GHSA-685m-2w69-288q>
protobufjs has overlong UTF-8 decoding - <https://github.com/advisories/GHSA-q6x5-8v7m-xcrf>
protobufjs: Denial of Service via unbounded recursive JSON descriptor expansion - <https://github.com/advisories/GHSA-jggg-4jg4-v7c6>
fix available via `npm audit fix`
node_modules/protobufjs

shell-quote 1.1.0 - 1.8.3
Severity: critical
shell-quote quote() does not escape newlines in object .op values - <https://github.com/advisories/GHSA-w7jw-789q-3m8p>
fix available via `npm audit fix`
node_modules/shell-quote

[...]

26 vulnerabilities (17 moderate, 7 high, 2 critical)

`npm audit` sur l'état pré-mission — extrait : les deux failles **critiques** (protobufjs, shell-quote) et le décompte final. Sortie complète : `docs/captures/audit-avant-complet.txt`

```
npm outdated — état pré-mission

timhrdy@MacBook-Pro-de-Tim Unify-App % npm outdated
Package      Current  Wanted  Latest  Location  Depended by
@babel/core  7.29.0   7.29.7   7.29.7   node_modules/@babel/core  Unify-App
@expo/metro-runtime  55.0.6  55.0.11  56.0.15  node_modules/@expo/metro-runtime  Unify-App
@expo/vector-icons  15.0.3   15.1.1   15.1.1   node_modules/@expo/vector-icons  Unify-App
@react-native-async-storage/async-storage  2.2.0    2.2.0    3.1.1    node_modules/@react-native-async-storage/async-storage  Unify-App
@react-native-community/netinfo  11.5.2   11.5.2   12.0.1   node_modules/@react-native-community/netinfo  Unify-App
@react-native-community/slider  5.1.2    5.1.2    5.2.0    node_modules/@react-native-community/slider  Unify-App
@react-navigation/bottom-tabs  6.6.1    6.6.1    7.18.0   node_modules/@react-navigation/bottom-tabs  Unify-App
@react-navigation/native  6.1.18   6.1.18   7.3.1    node_modules/@react-navigation/native  Unify-App
@react-navigation/native-stack  6.11.0   6.11.0   7.17.3   node_modules/@react-navigation/native-stack  Unify-App
@supabase/supabase-js  2.96.0   2.108.1  2.108.1  node_modules/@supabase/supabase-js  Unify-App
@types/lodash  4.17.23  4.17.24  4.17.24  node_modules/@types/lodash  Unify-App
@types/react  19.2.14  19.2.17  19.2.17  node_modules/@types/react  Unify-App
eslint       8.57.1   8.57.1   10.4.1    node_modules/eslint  Unify-App
expo         55.0.26  55.0.26  56.0.11  node_modules/expo  Unify-App
expo-apple-authentication  55.0.8   55.0.13  56.0.4    node_modules/expo-apple-authentication  Unify-App
expo-auth-session  55.0.7   55.0.16  56.0.14   node_modules/expo-auth-session  Unify-App
expo-crypto   55.0.9   55.0.15  56.0.4    node_modules/expo-crypto  Unify-App
expo-dev-client  55.0.11  55.0.35  56.0.20   node_modules/expo-dev-client  Unify-App
expo-font     55.0.8   55.0.8   56.0.6    node_modules/expo-font  Unify-App
expo-image-picker  55.0.11  55.0.20  56.0.17   node_modules/expo-image-picker  Unify-App
expo-linear-gradient  55.0.8   55.0.14  56.0.4    node_modules/expo-linear-gradient  Unify-App
expo-location  55.1.2   55.1.10  56.0.17   node_modules/expo-location  Unify-App
expo-notifications  55.0.11  55.0.23  56.0.17   node_modules/expo-notifications  Unify-App
expo-secure-store  55.0.8   55.0.14  56.0.4    node_modules/expo-secure-store  Unify-App
expo-status-bar  55.0.4   55.0.6   56.0.4    node_modules/expo-status-bar  Unify-App
expo-task-manager  55.0.9   55.0.16  56.0.18   node_modules/expo-task-manager  Unify-App
expo-web-browser  55.0.9   55.0.16  56.0.5    node_modules/expo-web-browser  Unify-App
firebase     MISSING  11.10.0  12.14.0   -  Unify-App
jest         29.7.0   29.7.0   30.4.2    node_modules/jest  Unify-App
prettier     3.8.1    3.8.4    3.8.4     node_modules/prettier  Unify-App
react        19.2.0   19.2.0   19.2.7    node_modules/react  Unify-App
react-dom    19.2.0   19.2.0   19.2.7    node_modules/react-dom  Unify-App
react-native  0.83.2   0.83.2   0.86.0    node_modules/react-native  Unify-App
react-native-chart-kit  6.12.0   6.12.3   6.12.3    node_modules/react-native-chart-kit  Unify-App
react-native-gesture-handler  2.30.0   2.30.1   3.0.1     node_modules/react-native-gesture-handler  Unify-App
react-native-maps  1.26.20  1.26.20  1.27.2    node_modules/react-native-maps  Unify-App
react-native-reanimated  4.2.1    4.2.1    4.4.1     node_modules/react-native-reanimated  Unify-App
react-native-safe-area-context  5.6.2    5.6.2    5.8.0     node_modules/react-native-safe-area-context  Unify-App
react-native-screens  4.23.0   4.23.0   4.25.2    node_modules/react-native-screens  Unify-App
react-native-svg  15.15.3  15.15.5  15.15.5   node_modules/react-native-svg  Unify-App
react-native-worklets  0.7.2    0.7.2    0.9.2     node_modules/react-native-worklets  Unify-App
typescript   5.9.3    5.9.3    6.0.3     node_modules/typescript  Unify-App
```

`npm outdated` sur l'état pré-mission : ~40 paquets en retard (React Navigation v6→v7, ESLint 8→10, écosystème Expo 55→56...)

3. Fiche de cadrage

Chantier	Détail	« Fait » = quand...
C1 — Mise à jour	NestJS 10 → 11 (majeure, breaking changes Express 5) ; suppression <code>firebase</code> (dépendance morte portant la faille critique) ; <code>lodash</code> 4.17.23 → 4.18.1 ; <code>@typescript-eslint</code> 6 → 8 ; correctifs lockfile (<code>node-forge</code> , <code>xmldom</code> , <code>shell-quote</code> ...). Plan de rollback : §C1.4	<code>npm audit</code> = 0 critique / 0 élevée sur les deux projets ; build + 14 tests verts
C2 — Correctif	Build du microservice cassé : <code>npm run build</code> → <code>error TS5095</code> . Fichiers : <code>micro-affil/tsconfig.json</code> , <code>micro-affil/.eslintrc.js</code>	<code>tsc</code> exit 0 ; lint 0 erreur ; tests verts
C3 — Évolutif	Guillaume Lafay — deep linking d'authentification + inscription via Edge Function Supabase. Fichiers : <code>App.tsx</code> , <code>AuthService</code> , <code>AuthContext</code>	Flux d'auth Google fonctionnel via deep link, testé sur device

Répartition : Tim Hrdy → C1 + C2 + rapport · Guillaume Lafay → C3.

4. C1 — Mise à jour & adaptation

4.1 Filet posé avant de toucher

Avant toute montée de version : exécution de la suite existante pour **figer le comportement de référence** — `npm test` : **14 tests / 4 suites, tous verts**. Ce même filet est rejoué après chaque étape.

4.2 Dépendances montées (avant → après)

Paquet	Avant	Après	Nature
@nestjs/common · core · platform-express	^10.0.0	^11.1.24	⚠ Majeure (breaking changes)
firebase (+ sous-arbre protobufjs / grpc)	^11.6.1	supprimé	Dépendance morte — élimine la faille critique
lodash	4.17.23	4.18.1	Faible élevée (Code Injection / Prototype Pollution)
@nestjs/cli / @nestjs/schematics	^10 / —	^11.0.21 / ^11.1.0	Outillage
@typescript-eslint/*	^6.0.0	^8.60.1	Outillage (corrige glob , minimatch , tmp ...)
@react-navigation/bottom-tabs , @rn-community/datetimestpicker (dans le backend !)	présentes	supprimées	Parasites — réduction de surface d'attaque
shell-quote (transitif, via react-devtools-core)	1.8.3	1.8.4	Faible critique publiée le 12/06, corrigée le jour même
node-forge , @xmldom/xmldom , flatted , minimatch , picomatch ... (transitifs)	vulnérables	corrigés via lockfile	Faibles élevées

Vérification de la dépendance morte avant suppression (preuve qu'on ne casse rien) :

```
$ grep -rn -i "firebase|firestore" . --exclude-dir=node_modules --exclude=package-lock.json
package.json:43:   "firebase": "^11.6.1",           ← seule occurrence côté JS
android/.../AndroidManifest.xml: com.google.firebase.messaging.* ← FCM natif
                                   (push expo-notifications, indépendant du paquet npm)
```

4.3 Breaking changes rencontrés (changelog lu)

Guide de migration officiel NestJS 11 (docs.nestjs.com/migration-guide) — points relevés et impact sur notre code :

Breaking change (changelog NestJS 11)	Impact sur <code>micro-affil</code>
Node.js ≥ 20 requis (16/18 abandonnés)	✅ OK — Node 22.13.1 en local et en CI
Express 4 → 5 dans @nestjs/platform-express (path-to-regexp v8 : les routes wildcard * doivent être nommées *splat , syntaxe des paramètres optionnels modifiée)	✅ Aucun impact — nos contrôleurs n'utilisent que des routes littérales (@Post() , @Get(':code'))
Parsing des query strings (Express 5, mode simple par défaut)	✅ Aucun impact — DTO validés par class-validator , pas de query imbriquée
cache-manager v6 si utilisé	✅ Non utilisé

Adaptation de code nécessaire : aucune dans `src/` — mais la montée a **révélé** une bombe à retardement dans la config TypeScript, traitée en Chantier 2 (un correctif ≠ un upgrade : périmètre séparé, commits séparés).

4.4 Plan de rollback

- Branche dédiée** : tout est sur `features/post-profil` — `main` n'est jamais touché ; tant que la PR n'est pas mergée, la prod ne voit rien.
- Commits atomiques** → retour arrière ciblé par `git revert <sha>` (upgrade, correctif et hygiène sont des commits distincts).
- Lockfiles = source de vérité** : `git checkout <sha-avant> -- package-lock.json && npm ci` restaure l'arbre de dépendances à l'identique en ~1 min.
- Builds EAS** : les binaires publiés sont immuables ; en cas de régression mobile, on re-soumet le build précédent (pas de hotfix sauvage).

4.5 Preuve de non-régression

```
$ npm run build      (micro-affil)
> tsc
BUILD_EXIT=0 - dist/src/main.js généré

$ npm test          (racine, après toutes les montées)
Test Suites: 4 passed, 4 total
Tests:       14 passed, 14 total

$ npm run test:cov   (micro-affil)
All files      | 100 % stmts | 100 % branch | 100 % funcs | 100 % lines
Tests:        7 passed, 7 total
```

Gain quantifié : 60 → 9 vulnérabilités (-85 %), **0 critique / 0 élevée** ; 2 failles critiques d'exécution de code éliminées ; bundle mobile allégé du SDK Firebase complet (inutilisé).

● timhrdy@MacBook-Pro-de-Tim Unify-App % npm test

```
> unify@1.0.0 test
> jest
```

```
PASS micro-affil/dist/test/create-affiliation-code.usecase.spec.js
PASS micro-affil/test/create-affiliation-code.usecase.spec.ts
PASS micro-affil/test/code-generator.service.spec.ts
PASS micro-affil/dist/test/code-generator.service.spec.js
```

```
Test Suites: 4 passed, 4 total
Tests:       14 passed, 14 total
Snapshots:   0 total
Time:        0.314 s, estimated 1 s
Ran all test suites.
```

Le filet de non-régression après toutes les montées de version : 14 tests / 4 suites, tous verts

5. C2 — Correctif : build du microservice cassé

Symptôme. Le microservice ne compile pas :

```
$ cd micro-affil && npm run build
> tsc
tsconfig.json(2,3): error TS5095: Option 'bundler' can only be used when
'module' is set to 'preserve' or to 'es2015' or later.
```

Reproduction. Systématique : `npm run build` échoue à chaque exécution, avant toute modification de code. (Le service tournait jusqu'ici en dev via `ts-node-dev --transpile-only`, qui ignore les erreurs de type — c'est pour ça que personne ne l'avait vu.)

Diagnostic — cause racine. Le `tsconfig.json` du backend se terminait par :

```
"extends": "expo/tsconfig.base"
```

Un backend NestJS (CommonJS) qui hérite de la config TypeScript d'Expo (front React Native). Cette base impose `moduleResolution: "bundler"` et `customConditions` — incompatibles avec `module: "commonjs"`. Probablement un copier-coller à la création du dossier dans le monorepo. Première correction tentée (`moduleResolution: "node"` seul) → nouvelle erreur TS5098 (`customConditions` hérité lui aussi) : traiter le symptôme ne suffisait pas, il fallait **supprimer l'héritage**, pas le rustiner.

Correction (`micro-affil/tsconfig.json`) :

```
"compilerOptions": {
  "module": "commonjs",
+  "moduleResolution": "node",
  ...
},
- "extends": "expo/tsconfig.base"
}
```

Dans la foulée, même famille de problème sur le lint : ESLint analysait les `.d.ts` générés dans `dist/` (21 erreurs de parsing) → exclusion de `dist/` et `coverage/` dans `.eslintrc.js`.

Test de non-régression.

```
$ npm run build → exit 0, dist/src/main.js généré
$ npm run lint → 0 erreur (21 → 0)
$ npm test → 14/14 verts
```

La compilation `tsc` (vérification de types complète, vs `--transpile-only` en dev) et le lint font désormais office de **garde-fou permanent** : toute réintroduction du problème casse le build immédiatement.

```
timhrdy@MacBook-Pro-de-Tim Unify-App % cd micro-affil
timhrdy@MacBook-Pro-de-Tim micro-affil % npm run build

> micro-affil@1.0.0 build
> tsc

tsconfig.json:2:3 - error TS5095: Option 'bundler' can only be used when 'module' is set to 'preserve' or to 'es2015' or later.

2  "compilerOptions": {
   ~~~~~

Found 1 error in tsconfig.json:2
```

Avant — `npm run build` sur l'état pré-mission : erreur TS5095 pointée sur le `compilerOptions` du `tsconfig`

```

● timhrdy@MacBook-Pro-de-Tim micro-affil % npm run build

> micro-affil@1.0.0 build
> tsc

○ timhrdy@MacBook-Pro-de-Tim micro-affil % █

```

Après — même commande après suppression de l'héritage `expo/tsconfig.base` : compilation sans erreur

6. C3 — Évolutif : deep linking d'authentification

Auteur : Guillaume Lafay — commit `efaad33`, complété par la PR #9 `fix-google-auth` (auteur vérifiable dans l'historique Git : `glafay`).

6.1 Contexte et problèmes à résoudre

Deux points bloquants existaient dans l'authentification :

1. **Pas de deep link.** Au retour du navigateur OAuth (Google), l'app ne récupérait pas la session : l'utilisateur arrivait sur un écran mort. Aucun handler n'écoutait l'URL de callback `com.unify.team://auth/callback`.
2. **Rate limit Supabase Auth.** L'inscription utilisait directement `supabase.auth.signUp()` côté client, soumis au rate limit public de Supabase (4 requêtes/heure/IP). Sur un événement de démonstration ou un test intensif, les inscriptions tombaient en erreur `429`.

6.2 Architecture d'authentification mise en place

Le schéma `com.unify.team` est déclaré dans `app.json` (iOS `bundleIdentifier` + Android `package`). Tous les flux d'auth redirigent vers `com.unify.team://auth/callback`.

```

Utilisateur
├── Inscription email/password
│   └── AuthService.register()
│       └── Edge Function register-user (Deno, admin API)
│           ├── admin.auth.admin.createUser() → auth.users
│           ├── admin.from('users').insert() → public.users
│           └── admin.generateLink(type:'signup', redirectTo: com.unify.team://auth/callback)
│               └── Resend API → email HTML branded
├── Connexion Google OAuth
│   └── AuthService.signInWithGoogle()
│       ├── supabase.auth.signInWithOAuth({ skipBrowserRedirect: true })
│       ├── WebBrowser.openAuthSessionAsync(url, redirectTo)
│       └── Parse tokens depuis result.url → supabase.auth.setSession()
├── Connexion Apple Sign-In (iOS)
│   └── AuthService.signInWithApple()
│       ├── AppleAuthentication.signInAsync()
│       └── supabase.auth.signInWithIdToken({ provider: 'apple', token: identityToken })
└── Deep link entrant (email de confirmation ou retour OAuth)
    └── DeepLinkHandler (App.tsx)
        ├── Linking.getInitialURL() → cold start
        ├── Linking.addEventListener('url') → app déjà ouverte
        ├── ?code= (PKCE) → exchangeCodeForSession(code)
        └── #access_token= (implicit) → setSession({ access_token, refresh_token })
            └── onAuthStateChanged() → setUser() → AppStack

```


6.3 Fichiers créés et modifiés

Fichier	Statut	Rôle
src/App.tsx	modifié (+50 lignes)	Composant <code>DeepLinkHandler</code>
src/services/AuthService.ts	modifié (+23 / -20 lignes)	<code>register()</code> → Edge Function
src/contexts/AuthContext.tsx	modifié (-6 lignes)	Suppression rate limit client
supabase/functions/register-user/index.ts	nouveau (+161 lignes)	Admin API + Resend
supabase/functions/send-auth-email/index.ts	nouveau (+183 lignes)	Hook email Supabase

6.4 DeepLinkHandler — App.tsx

Le composant `DeepLinkHandler` est placé **avant** `NavigationSwitcher` dans l'arbre React, ce qui garantit que les tokens sont enregistrés avant que la navigation ne décide de l'écran à afficher.

Il gère deux variantes de callback selon la configuration Supabase :

- **PKCE** (`?code=`) : flux recommandé. Le code d'autorisation est échangé contre des tokens via `supabase.auth.exchangeCodeForSession(code)` .
- **Implicit** (`#access_token=&refresh_token=`) : flux de fallback. Les tokens arrivent directement dans le fragment d'URL ; `supabase.auth.setSession()` les enregistre immédiatement.

```
function DeepLinkHandler() {
  useEffect(() => {
    const handleUrl = async ({ url }: { url: string }) => {
      if (!url.includes("auth/callback")) return;
      try {
        const parsed = Linking.parse(url);
        const code = parsed.queryParams?.code as string | undefined;
        if (code) {
          await supabase.auth.exchangeCodeForSession(code);
          return;
        }
        const fragment = url.split("#")[1];
        if (fragment) {
          const params = new URLSearchParams(fragment);
          const accessToken = params.get("access_token");
          const refreshToken = params.get("refresh_token");
          if (accessToken && refreshToken)
            await supabase.auth.setSession({ access_token: accessToken, refresh_token: refreshToken });
        }
      } catch (e) {
        if (__DEV__) console.error("[DeepLink] Erreur:", e);
      }
    };

    Linking.getInitialURL().then(url => { if (url) handleUrl({ url }); });
    const sub = Linking.addEventListener("url", handleUrl);
    return () => sub.remove();
  }, []);
  return null;
}
```

`Linking.getInitialURL()` couvre le **cold start** (app lancée depuis le lien email) ; l'event listener couvre le cas où l'app est déjà ouverte en arrière-plan.

6.5 Edge Function `register-user`

Avant ce chantier, l'inscription appelait `supabase.auth.signUp()` directement depuis le client mobile — soumis au rate limit public. L'Edge Function utilise la **Service Role Key** (pas de rate limit), ce qui permet autant d'inscriptions que nécessaire.

Déroulé de l'Edge Function :

```
POST /functions/v1/register-user { name, email, password }
├─ 1. admin.auth.admin.createUser({ email, password, user_metadata: { name }, email_confirm: false })
│   └─ → Crée l'entrée dans auth.users, email non confirmé
│       └─ → Si "already registered" → 409 "Cette adresse email est déjà utilisée."
├─ 2. admin.from('users').insert({ auth_user_id, email, name, created_at })
│   └─ → Crée le profil dans public.users
├─ 3. admin.generateLink({ type: 'signup', email, redirectTo: 'com.unify.team://auth/callback' })
│   └─ → Lien OTP valide 24h
└─ 4. Resend API → email HTML branded (dégradé #7D80F4, bouton CTA, lien de secours)
    └─ → { success: true, emailSent: true }
```

Gestion des cas limites :

Cas	Traitement
Email déjà enregistré	409 + message utilisateur explicite
Resend indisponible	L'user est créé ; emailSent: false retourné (pas de blocage)
Lien OTP expiré (>24h)	L'utilisateur doit relancer l'inscription
name ou email manquant	400 "name, email et password sont requis"

6.6 Sécurité et validation

Côté client (AuthService.ts) :

- Email normalisé (trim + lowercase) avant tout appel réseau.
- Mot de passe validé selon les critères OWASP/NIST 2024 : 8+ caractères, majuscule, minuscule, chiffre, caractère spécial — erreur explicite par critère manquant.
- Nom sanitisé : trim + collapse des espaces multiples + max 100 caractères.

Côté Edge Function :

- Le rate limiting client (checkRateLimit() dans AuthContext) a été **supprimé** : il n'avait pas de sens côté client (contournable) et est maintenant géré par l'admin API qui n'en a pas besoin.
- La Service Role Key n'est jamais exposée au client — elle est uniquement lue depuis les variables d'environnement Deno (Deno.env.get('SUPABASE_SERVICE_ROLE_KEY')).

Persistence des tokens (supabase.ts) :

- iOS / Android : expo-secure-store (stockage chiffré natif).
- Web : localStorage (fallback).
- detectSessionInUrl: false : désactivé car la session est gérée manuellement par DeepLinkHandler .

6.7 Flux email / reset password

L'Edge Function send-auth-email est enregistrée comme **Auth Hook** dans le dashboard Supabase (déclenché sur les événements signup , recovery , email_change). Elle remplace l'email par défaut de Supabase par un template HTML au design Unify.

Pour le **reset password**, le flux est identique : l'OTP est intégré dans un lien /auth/v1/verify?type=recovery&redirect_to=com.unify.team://auth/callback , le deep link est intercepté, et l'app redirige vers ResetPasswordScreen pour saisir le nouveau mot de passe.

6.8 Test du flux complet

Scénario vérifié sur l'application (12 juin 2026) :

1. **Inscription** — saisie du nom, de l'email et du mot de passe ; appel à l'Edge Function → utilisateur créé dans auth.users (non confirmé) + profil dans public.users .
2. **Email reçu** — email Resend avec bouton "Confirmer mon compte" (template HTML branded).
3. **Clic sur le lien** — Supabase valide l'OTP et redirige vers com.unify.team://auth/callback avec les tokens.
4. **Deep link intercepté** — DeepLinkHandler extrait access_token + refresh_token et appelle supabase.auth.setSession() .
5. **Session active** — onAuthStateChanged déclenche le chargement du profil ; l'utilisateur est redirigé vers l'écran principal, authentifié.

Confirmez votre compte Unify

UNIFY

Votre plateforme de running

Confirmez votre compte

Bonjour,

Merci de vous être inscrit sur Unify ! Cliquez sur le bouton ci-dessous pour activer votre compte :

Confirmer mon compte

Si le bouton ne fonctionne pas, copiez ce lien dans votre navigateur :

https://muhexuopzmqdxonurktn.supabase.co/auth/v1/verify?token=6b2292b7ca76032f150da1a6fc7b745f4800500d6f9dc1cf5b7a6061&type=signup&redirect_to=com.unify.team://auth/callback

Email de confirmation reçu via Resend — template HTML branded avec bouton CTA et lien de secours. Le lien encode le deep link `com.unify.team://auth/callback` comme `redirect_to`.

guillaume.lafay

guillaume.lafay@icloud.com

Modifier le profil

SÉCURITÉ

Vérification d'identité

Renforcez la sécurité de la communauté

Non vérifié

Vérifier mon identité

CONFIDENTIALITÉ

Recherche par genre

Limiter la recherche aux personnes du même genre

Masquer ma position exacte

Afficher une zone approximative plutôt que ma position précise

PRÉFÉRENCES DE COURSE

Allure similaire

Afficher uniquement les coureur(se)s avec une allure proche (± 1 min/km)

Écran de profil après confirmation par deep link — session Supabase active, utilisateur authentifié et profil chargé depuis `public.users`.

7. Tableau de bord « après » + hygiène Git

Indicateur	App mobile (racine)	Microservice <code>micro-affil</code>
Vulnérabilités (<code>npm audit</code>)	9 modérées (0 critique, 0 élevée) — 24 → 9	0 — 36 → 0
Dépendances obsolètes	41 paquets* (écosystème Expo 55, voir §8)	18 (transitifs mineurs)
Build / lint OK ?	Tests OK	Build OK · Lint OK (réparés)
Nb de tests / couverture	14/14 verts (inchangé = non-régression)	7/7 verts · couverture 100 % des unités testées
Temps de réponse clé (back)	—	<i>non mesuré (env Supabase requis)</i>

* Les 9 vulnérabilités modérées restantes sont **toutes** dans l'outillage de build Expo (`@expo/cli` , `xcode` , `metro-config` ...), non embarqué dans l'app livrée. Le seul « fix » proposé par npm est un **downgrade Expo 55 → 46** (`isSemVerMajor`), refusé car destructeur. Vraie remédiation : **migration Expo SDK 56**, planifiée comme chantier dédié.

```
$ npm audit # racine, après
9 moderate severity vulnerabilities

$ cd micro-affil && npm audit # microservice, après
found 0 vulnerabilities
```

Hygiène Git — branche dédiée `mission/dev-legacy` ne contenant **que** le périmètre de la mission (5 commits atomiques, 1 commit = 1 intention), en PR vers la branche de travail :

```
* b74f6f7 chore(micro-affil): exclude dist/ et coverage/ du lint
* f96ce87 security: fix critique shell-quote (GHSA-w7jw-789q-3m8p) via npm audit fix
* 430203b security: audit et correction des vulnérabilités des dépendances
* d9944a8 Merge pull request #9 from guiguil03/fix-google-auth
| * fc8ec92 fix auth
* | efaad33 Add deep link handling for authentication in App component; ...
```

```

timhrdy@MacBook-Pro-de-Tim Unify-App % npm audit
# npm audit report

uuid <11.1.1
Severity: moderate
uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided - https://github.com/advisories/GHSA-w5hq-g745-h8pq
fix available via `npm audit fix --force`
Will install expo@46.0.21, which is a breaking change
node_modules/uuid
  xcode >=0.9.2
  Depends on vulnerable versions of uuid
  node_modules/xcode
    @expo/config-plugins *
    Depends on vulnerable versions of xcode
    node_modules/@expo/config-plugins
      @expo/cli <=0.0.0-canary-20231123-1b19f96-4 || >=0.0.1-canary-20231125-d600e44
      Depends on vulnerable versions of @expo/config
      Depends on vulnerable versions of @expo/config-plugins
      Depends on vulnerable versions of @expo/metro-config
      Depends on vulnerable versions of @expo/prebuild-config
      node_modules/@expo/cli
        expo 40.0.0-alpha.0 - 40.0.0-beta.5 || >=41.0.0-alpha.0
        Depends on vulnerable versions of @expo/cli
        Depends on vulnerable versions of @expo/config
        Depends on vulnerable versions of @expo/config-plugins
        Depends on vulnerable versions of @expo/local-build-cache-provider
        Depends on vulnerable versions of @expo/metro-config
        node_modules/expo
          @expo/config <=0.0.1-canary-20240418-8d74597 || >=3.3.23-alpha.0
          Depends on vulnerable versions of @expo/config-plugins
          node_modules/@expo/config
            @expo/local-build-cache-provider *
            Depends on vulnerable versions of @expo/config
            node_modules/@expo/local-build-cache-provider
              @expo/metro-config <=0.0.1-canary-20240418-8d74597 || >=0.1.49-alpha.0
              Depends on vulnerable versions of @expo/config
              node_modules/@expo/metro-config
                @expo/prebuild-config *
                Depends on vulnerable versions of @expo/config
                Depends on vulnerable versions of @expo/config-plugins
                node_modules/@expo/prebuild-config

9 moderate severity vulnerabilities

To address issues that do not require attention, run:
  npm audit fix

To address all issues (including breaking changes), run:
  npm audit fix --force

```

`npm audit` après la mission : 9 modérées, toutes dans la chaîne d'outillage `uuid` → `xcode` → `@expo/*`. On y voit la ligne « Will install expo@46.0.21, which is a breaking change » — le downgrade destructeur proposé par npm et refusé (§8)

📸 Capture à insérer : page de la PR GitHub ([PR #11](#)) avec l'historique des commits

8. Bilan & rétro legacy

Ce que les vieilles deps / le vieux code ont coûté :

- La faille **critique** (exécution de code arbitraire via `protobufjs`) venait d'un SDK **que personne n'utilisait**. Firebase a été ajouté un jour, jamais branché, jamais retiré : chaque dépendance « au cas où » est une dette de sécurité qui court toute seule.
- Le build du microservice était cassé **silencieusement** depuis sa création : le mode dev (`--transpile-only`) masquait l'erreur de config. Sans CI qui compile, un projet peut être indéployable sans que personne ne le sache.
- Une **nouvelle faille critique est apparue entre nos deux sessions** (`shell-quote` , advisory du 12/06) : la sécurité des dépendances n'est pas un état, c'est un flux. Un audit ponctuel périmé en jours.

Ce qu'on change dans nos habitudes :

- `npm audit --audit-level=high` **bloquant en CI** + compilation `tsc` du microservice à chaque PR (plus jamais de build cassé silencieux).
- Dependabot/Renovate** sur le dépôt : les correctifs de sécurité arrivent en PR automatiques, petits et fréquents, au lieu d'un rattrapage massif et risqué.
- Une **dépendance ajoutée = une dépendance justifiée** ; revue trimestrielle de `npm outdated` pour ne plus accumuler 40 paquets de retard.
- Ne pas mélanger les intentions dans un commit** : notre premier commit (430203b) regroupait l'upgrade C1 et le correctif C2 — les deux suivants sont redevenus atomiques. Leçon intégrée en cours de mission.
- Sortir les artefacts de build (`Unify.app/` , `dist/`) du dépôt et du lint : `.gitignore` à compléter.

Prochaine échéance identifiée : migration **Expo SDK 56** (efface les 9 vulnérabilités résiduelles) — à mener avec la même méthode : file, changelog, branche dédiée, rollback.

Annexe A — Journal de bord

Horodatage	Événement
05/06 ~23h15	Reprise du projet. <code>npm audit</code> : 24 vulnérabilités app (1 critique) / 36 micro (1 critique). <code>npm outdated</code> : 40+ paquets en retard.
05/06 ~23h30	Filet posé : <code>npm test</code> → 14/14 verts (comportement de référence figé).
05/06 ~23h40	<code>npm audit fix --dry-run</code> sur les deux projets pour trier correctifs sûrs / cassants. Décision : refuser <code>--force</code> (proposait un downgrade Expo 55 → 46).
05/06 ~23h50	<code>npm audit fix</code> racine : 24 → 10. Critique <code>protobufjs</code> et toutes les élevées corrigées via lockfile.
06/06 ~00h05	micro-affil : lecture du guide de migration NestJS 11 (Node ≥ 20 ✓, Express 5, routes wildcard nommées — non concernés). Suppression des 2 deps RN parasites. Montée NestJS 10 → 11 + <code>@typescript-eslint</code> 8.
06/06 ~00h15	Impasse n°1 : <code>npm run build</code> → <code>error TS5095</code> . Première piste (<code>moduleResolution: "node"</code>) → nouvelle erreur <code>TS5098</code> .
06/06 ~00h25	Cause racine trouvée : <code>extends: "expo/tsconfig.base"</code> dans le <code>tsconfig</code> du backend. Suppression de l'héritage → build vert. Le service ne compilait en fait jamais (<code>--transpile-only</code> masquait tout).
06/06 ~00h35	Dernier <code>npm audit fix</code> micro (<code>glob</code>) → 0 vulnérabilité . Re-build + re-test : verts.
06/06 ~00h45	Question d'équipe : « on n'utilise pas Firebase, si ? » → vérif par grep : aucun import . Suppression de <code>firebase</code> → sous-arbre <code>protobufjs</code> / <code>grpc</code> éliminé à la racine. Tests verts.
06/06 00h59	Commit <code>430203b</code> (audit + correctifs) — <i>rétrospectivement trop gros : mélange C1/C2, voir rétro</i> . Push.
12/06 ~02h00	Relecture de l'énoncé exact. Re-audit de contrôle : nouvelle faille critique apparue entre-temps (<code>shell-quote</code> , GHSA-w7jw-789q-3m8p, advisory publié après notre session).
12/06 02h17	Fix <code>shell-quote</code> 1.8.3 → 1.8.4 (<code>npm audit fix</code> , non-cassant), tests verts. Commit atomique <code>f96ce87</code> .
12/06 ~02h25	Lint micro-affil : 21 erreurs de parsing (<code>dist/</code> analysé par ESLint). Exclusion <code>dist/ + coverage/</code> → 0 erreur. Commit atomique <code>b74f6f7</code> . <code>npm run test:cov</code> : 100 % sur les unités testées.
12/06 ~02h40	Refonte du compte-rendu selon le canevas du sujet.

Annexe B — Référence

Rapport d'audit détaillé (CVE par CVE, CVSS, CWE) : `docs/AUDIT-SECURITE.md` dans le dépôt.